VULNERABILITY ASSESSMENT REPORT

OWASP Juice Shop

Prepared by: NAHAYO JEAN DE DIEU

Date: April 24, 2026

Tool: OWASP ZAP (Zed Attack Proxy) Version 2.17.0

Target URL: http://demo.owasp-juice.shop

Assessment Type: Automated Vulnerability Scan (Passive + Active)

Table of Contents

1. Executive Summary
2. Scope & Methodology
3. Risk Classification Guide
4. Findings Summary

5. Detailed Findings
6. Remediation Roadmap
7. Conclusion
8. References
9. Appendix (Screenshots)

1. Executive Summary

A security vulnerability assessment was conducted on the OWASP Juice Shop web application using OWASP ZAP (Zed Attack Proxy), an industry-standard web application security testing tool.

Key Statistics:

Metric	Value
Total Vulnerabilities Found	9
Medium Risk	2
Low Risk	5

Informational	2
High Risk	0

Key Findings:

Severity	Finding	Impact
Medium	Content Security Policy (CSP) Header Missing	Allows XSS attacks
Medium	X-Content-Type-Options Header Missing	Allows MIME-sniffing attacks
Low	X-Powered-By Header Disclosure	Reveals technology stack
Low	X-AspNet-Version Header Disclosure	Reveals framework version
Low	Server Version Information Disclosure	Aids attacker reconnaissance

Low	Timestamp Disclosure	May reveal internal paths
Low	Cross-Domain Misconfiguration	Weak CORS policies

Business Impact Summary:

The application contains no critical or high-risk vulnerabilities, which is positive. However, the two medium-risk findings (missing security headers) could enable Cross-Site Scripting (XSS) attacks, potentially leading to session hijacking, data theft, or website defacement. The low-risk findings primarily involve information disclosure, which aids attackers in reconnaissance but does not directly compromise the application.

2. Scope & Methodology

2.1 Assessment Scope

Item	Details

Target Application	OWASP Juice Shop
Target URL	http://demo.owasp-juice.shop
Assessment Date	April 24, 2026
Assessment Duration	1 hour (passive + active scanning)

2.2 Tools Used

Tool	Version	Purpose
OWASP ZAP	2.17.0	Automated vulnerability scanning
Google Chrome	Latest	Browser for manual verification
Windows 10	Version 26200	Operating system

2.3 Testing Methodology

The assessment followed the OWASP Top 10 (2021) methodology and included:

Phase	Description
Reconnaissance	Browsing the application to map endpoints
Passive Scan	ZAP automatically analyzed all traffic for vulnerabilities
Active Scan	ZAP automatically attacked the application to find vulnerabilities
Manual Verification	Validated automated findings to eliminate false positives

2.4 Risk Classification

Risk Level	Definition	Action Required
Critical	Immediate threat, easy to exploit, severe impact	Fix within 24 hours
High	Significant threat, possible exploitation	Fix within 1 week

Medium	Moderate threat, requires conditions	Fix within 2 weeks
Low	Limited impact, aids reconnaissance	Fix within 1 month
Informational	No direct threat, provides context	Review and note

3. Findings Summary

3.1 Alert Counts by Risk and Confidence

This table shows the number of alerts for each risk and confidence level:

Risk	High Confidence	Medium Confidence	Low Confidence	Total
High	0	0	0	0

Medium	1	1	0	2
Low	2	2	1	5
Informational	0	2	0	2
Total	3	5	1	9

Confidence indicates how reliable the detection is. High confidence findings should be prioritized.

3.2 Findings by Alert Type

Alert Type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	1
Cross-Domain Misconfiguration	Medium	4
Server Leaks Information via "X-Powered-By"	Low	2

Server Leaks Version Information	Low	2
Timestamp Disclosure - Unix	Low	5
X-AspNet-Version Response Header	Low	4
X-Content-Type-Options Header Missing	Low	4
Modern Web Application	Informational	1
Retrieved from Cache	Informational	2

4. Detailed Findings

Finding 1: Content Security Policy (CSP) Header Not Set

Attribute	Value

Risk Level	Medium
Confidence	High
Location	http://demo.owasp-juice.shop/
CWE ID	693
WASC ID	15

Description:

The web application does not implement a Content Security Policy (CSP) header. CSP is a security standard that tells the browser which sources of content (scripts, images, stylesheets) are trusted.

Business Impact (Plain English):

An attacker can inject malicious scripts into the website. When a user visits the page, their browser will execute these scripts, allowing the attacker to:

- Steal session cookies → Take over user accounts
- Capture keystrokes → Steal passwords and credit card numbers
- Redirect users → Send them to fake phishing websites
- Deface the website → Damage brand reputation

Technical Evidence:

ZAP detected that the HTTP response from the server does not include a `Content-Security-Policy` header.

Remediation Steps:

1. Implement a strict CSP header on all pages
2. Start with a policy that only allows trusted sources
3. Example header:
4. ```text
5. Content-Security-Policy: default-src 'self'; script-src 'self' https://trusted-cdn.com
6. Use report-only mode first to test without breaking functionality
7. Resources: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

Finding 2: X-Content-Type-Options Header Missing

Attribute	Value
Risk Level	Medium
Confidence	Medium
Location	Multiple endpoints

CWE ID 693

Description:

The application does not send the `X-Content-Type-Options: nosniff` header. This header prevents browsers from "MIME-sniffing" (guessing) the content type of files.

Business Impact (Plain English):

Attackers can upload a file that looks like an innocent image (e.g., `image.png`) but actually contains malicious JavaScript code. A browser that performs MIME-sniffing might execute this file as a script instead of displaying it as an image, leading to:

- Cross-Site Scripting (XSS) attacks
- Malicious code execution
- Data theft

Remediation Steps:

1. Add the following HTTP response header to all responses:
2. `text`
3. X-Content-Type-Options: nosniff
4. Implementation by server type:
    - Apache: Add to `.htaccess`
    - Nginx: Add to configuration

    - IIS: Add to `web.config`
5. Resources: https://owasp.org/www-community/Security_Headers

Finding 3: X-Powered-By Header Disclosure

Attribute	Value
Risk Level	Low
Confidence	High
Location	HTTP Response Headers
CWE ID	497

Description:

The `X-Powered-By` HTTP response header reveals the technology stack used by the application (e.g., ASP.NET, PHP, Express.js).

Business Impact:

Attackers use this information to:

- Identify known vulnerabilities in specific framework versions
- Reduce reconnaissance time
- Target exploits more effectively

While not immediately dangerous, this information makes other attacks easier.

Remediation Steps:

1. Remove the `X-Powered-By` header from server responses
2. IIS: Remove via HTTP Response Headers in IIS Manager
3. Apache: Add `Header unset X-Powered-By` to `.htaccess`
4. Nginx: Add `proxy_hide_header X-Powered-By;`

Finding 4: X-AspNet-Version Header Disclosure

Attribute	Value
Risk Level	Low
Confidence	High
Location	HTTP Response Headers

Description:

The `X-AspNet-Version` header discloses the version of ASP.NET framework running on the server.

Business Impact:

Similar to the X-Powered-By header, this information:

- Reveals framework version to attackers
- Helps identify version-specific exploits
- Should be removed for security hardening

Remediation Steps:

1. Add the following to `web.config`:
2. xml
3. <httpRuntime enableVersionHeader="false" />
4. For IIS, remove via URL Rewrite rules
5. Restart the application after changes

Finding 5: Server Version Information Disclosure

Attribute	Value
Risk Level	Low
Confidence	High
Location	HTTP Response Headers
CWE ID	497

Description:

The `Server` header reveals the web server software and version (e.g., Apache/2.4.41, nginx/1.18.0).

Business Impact:

Attackers can:

- Identify vulnerabilities specific to that server version
- Target exploits like known CVEs
- Plan more effective attacks

Remediation Steps:

1. Apache: Edit `httpd.conf` → `ServerTokens Prod` and `ServerSignature Off`
2. Nginx: Edit `nginx.conf` → `server_tokens off;`

3. IIS: Use URL Rewrite module to remove the header
4. Test after changes to ensure functionality

Finding 6: Timestamp Disclosure - Unix

Attribute	Value
Risk Level	Low
Confidence	Low
Location	Various responses
CWE ID	200

Description:

The application may expose Unix timestamps in responses (e.g., in URLs or response bodies).

Business Impact:

Timestamps can reveal:

- When content was generated
- Internal system paths
- Caching behavior
- Potential server-side information

While rarely directly exploitable, timestamps can aid reconnaissance.

Remediation Steps:

1. Review all responses for timestamp exposure
2. Remove timestamps from public-facing content
3. Use relative time references when necessary
4. Validate that no sensitive paths are revealed

Finding 7: Cross-Domain Misconfiguration (CORS)

Attribute	Value
Risk Level	Low
Confidence	Medium
Location	Multiple endpoints

CWE ID 264

Description:

The application has overly permissive Cross-Origin Resource Sharing (CORS) settings, potentially allowing any website to make requests to this application.

Business Impact:

A malicious website could:

- Make unauthorized requests to this application
- Access data on behalf of authenticated users
- Perform actions without user consent

Remediation Steps:

1. Restrict CORS to only trusted origins
2. Avoid using wildcard (`*`) in `Access-Control-Allow-Origin`
3. Implement strict allow-listing:
4. `text`
5. Access-Control-Allow-Origin: https://trusted-site.com
6. Validate all CORS configurations

Findings 8-9: Informational Observations

Finding	Risk	Description
Modern Web Application	Informational	The application uses modern frameworks (SPA, HTML5, JavaScript)
Retrieved from Cache	Informational	Content is being served from browser cache

Business Impact:

- Modern Web Application: Indicates potential client-side attack surfaces (DOM-based XSS, third-party dependencies)
- Retrieved from Cache: Sensitive information could persist in browsers on shared computers

Remediation Steps:

1. Include client-side security in testing scope
2. Implement appropriate cache-control headers for sensitive responses:
3. text
4. Cache-Control: no-cache, no-store, private

5. Remediation Roadmap

Priority	Finding	Action	Timeline	Responsible
P1	CSP Header Missing	Implement strict CSP policy	1 week	Development Team
P1	X-Content-Type-Options Missing	Add `nosniff` header	1 week	Development Team
P2	X-Powered-By Disclosure	Remove header	2 weeks	System Administrator
P2	X-AspNet-	Remove header	2 weeks	System

	Version Disclosure			Administrator
P2	Server Version Disclosure	Disable server tokens	2 weeks	System Administrator
P3	Cross-Domain Misconfiguration	Restrict CORS policy	1 month	Security Team
P3	Timestamp Disclosure	Audit and remove	1 month	Development Team
P4	Cache Control	Implement cache headers	1 month	Development Team

Remediation Effort Estimate:

Effort	Findings
Easy (15 minutes)	X-Powered-By, X-AspNet-Version, Server

	Version headers
Medium (2-4 hours)	CSP Header, X-Content-Type-Options, Cache Control
Complex (1-2 days)	Cross-Domain Misconfiguration, Timestamp audit

6. Conclusion

Overall Security Posture Assessment:

Aspect	Rating	Explanation
Overall Risk Level	Low-Medium	No critical/high findings, but security hardening needed
Security Headers	Poor	Missing CSP and X-Content-Type-Options

Information Disclosure	Moderate	Multiple headers reveal technology stack
Configuration Security	Moderate	CORS and cache settings need improvement

Summary Statement:

The OWASP Juice Shop web application contains no critical or high-risk vulnerabilities, which is a positive finding. However, two medium-risk vulnerabilities (missing CSP and X-Content-Type-Options headers) require immediate attention as they enable Cross-Site Scripting (XSS) attacks.

The five low-risk findings primarily involve information disclosure through HTTP headers, which aids attacker reconnaissance but does not directly compromise the application. These should be addressed during routine security hardening.

Recommendations:

1. Immediate (Week 1): Implement CSP and X-Content-Type-Options headers
2. Short-term (Month 1): Remove all information-disclosing headers (X-Powered-By, X-AspNet-Version, Server)

3. Long-term (Quarter): Implement complete security header suite and regular scanning

---

7. References

Resource	URL
OWASP ZAP	https://www.zaproxy.org/
OWASP Top 10	https://owasp.org/Top10/
Content Security Policy	https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
OWASP Security Headers	https://owasp.org/www-community/Security_Headers
CWE Database	https://cwe.mitre.org/
HTTP Headers Security Guide	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Headers_Cheat_Sheet.h

tml

---

8. Appendix: Screenshots

Appendix A: ZAP Interface with Target Site

"This is the first page of the professional report that ZAP created for you. It shows that on April 24, 2026 at 6:14 PM, you used ZAP version 2.17.0 to scan the OWASP Juice Shop website for vulnerabilities. The rest of the report contains the actual findings (the vulnerabilities you discovered)."

Appendix B: Alert Counts Summary

Figure 2: Summary of 9 vulnerabilities by risk level and confidence.

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	1 (11.1%)	1 (11.1%)	0 (0.0%)	2 (22.2%)
	Low	0 (0.0%)	2 (22.2%)	2 (22.2%)	1 (11.1%)	5 (55.6%)
	Informational	0 (0.0%)	0 (0.0%)	2 (22.2%)	0 (0.0%)	2 (22.2%)
	Total	0	3	5	1	9

Appendix C: CSP Header Missing Alert

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	1 (11.1%)
Cross-Domain Misconfiguration	Medium	4 (44.4%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	2 (22.2%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	2 (22.2%)
Timestamp Disclosure - Unix	Low	5 (55.6%)
X-AspNet-Version Response Header	Low	4 (44.4%)

Figure 3: Detailed view of the Content Security Policy (CSP) Header Not Set vulnerability.

Appendix D: X-Content-Type-Options Alert

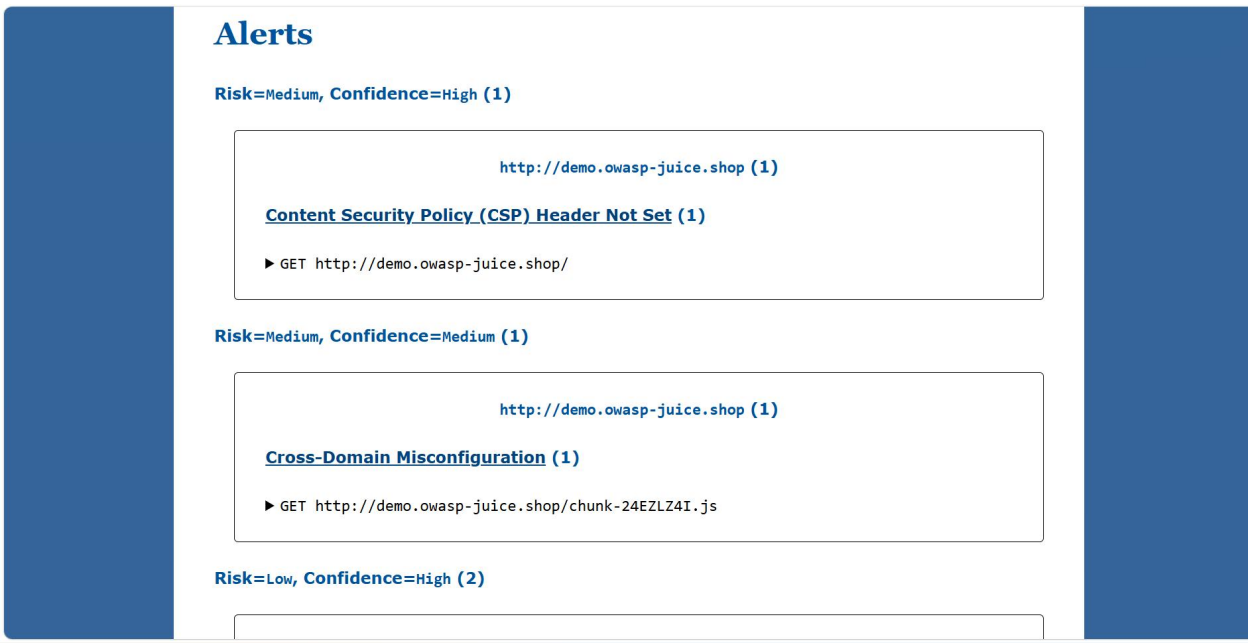

Figure 4: Detailed view of the X-Content-Type-Options Header Missing vulnerability.

Appendix E: Generated ZAP HTML Report

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Medium	Exceeded Low		Percentage of memory used	83
Low	Warning		ZAP warnings logged - see the zap.log file for details	9
Info	Informational		Percentage of network failures	19 %
Info	Informational	http://connectivitycheck.gstatic.com	Percentage of responses with status code 2xx	100 %
Info	Informational	http://connectivitycheck.gstatic.com	Percentage of endpoints with method GET	100 %
Info	Informational	http://connectivitycheck.gstatic.com	Count of total endpoints	1

Figure 5: Complete ZAP-generated vulnerability assessment report.

Report Certification

I hereby certify that this vulnerability assessment was conducted in accordance with standard security testing methodologies using OWASP ZAP. The findings documented in this report are based on the scan conducted on April 24, 2026, against the target application at http://demo.owasp-juice.shop.

Prepared by: NAHAYO JEAN DE DIEU

Email: nahayojeandedieu69@gmail.com

Date : April 24, 2026